

Cybersecurity & Blockchain

KGSP Enrichment [Week 3 & 4 – 2026]





Mudassar Aslam

(FHEA, PhD Cybersecurity)

Associate Professor of Cybersecurity & Program Director,
School of Engineering, Computing and Mathematics,
Oxford Brookes University,
Oxford, United Kingdom.
maslam@brookes.ac.uk

www.mudassir.info

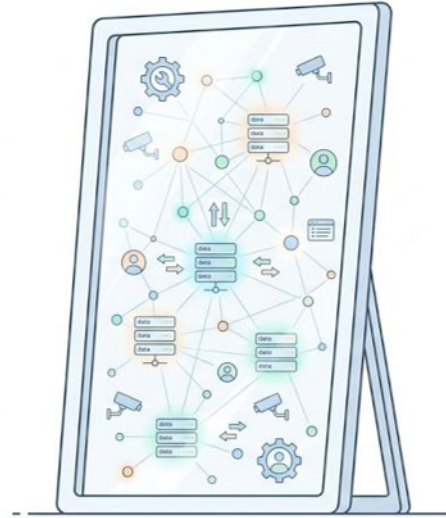


Day 05 – Privacy



Privacy is not Secrecy. It's Control

- **The Misconception:** "Privacy means hiding bad things."
- **The Reality:** Privacy isn't about having secrets; it's about having boundaries. It's the power to selectively reveal yourself to the world.
- **Definition:** Privacy is the mathematical and programmatic control over data lifecycle
 - who reads it
 - who stores it
 - who profits from it.
- Every time you click "**Accept All**," you aren't just letting a site load; you are signing away the **rights to your behavioral telemetry**.



Types of Private Information - I

Personal Identifiable Information (PII)

Information that can be used to identify an individual, either on its own or in combination with other information.

Examples: Name, address, phone number, email address, Social Security number, driver's license number.

Sensitive Personal Information (SPI)

A subset of PII that is more sensitive and requires higher protection due to the potential for discrimination or harm.

Examples: Racial or ethnic origin, political opinions, religious beliefs, genetic data, biometric data.

Health Information

Information related to an individual's physical or mental health, often protected under laws like HIPAA in the United States.

Examples: Medical records, health insurance details, health status, treatment information.

Online Activity Information

Data generated from an individual's activities on the internet, often used for profiling and targeted advertising.

Examples: Browsing history, search queries, social media activity, IP addresses.

Communication Data

Information about an individual's communications, including the content and metadata (e.g., time, duration, participants).

Examples: Emails, phone calls, text messages, instant messaging.

Employment Information

Data related to an individual's professional life, often held by employers and relevant to professional reputation and opportunities.

Examples: Job history, performance evaluations, salary information, disciplinary records.

Types of Private Information - II

Financial Information

Data related to an individual's financial status and transactions, which can be highly sensitive due to the risk of fraud or identity theft.

Examples: Bank account numbers, credit card details, income, credit history, tax information.

Location Information

Information about an individual's whereabouts and movements, which can reveal patterns and behaviors.

Examples: GPS data, travel records, home and work addresses.

Educational Information

Information related to an individual's educational background, typically held by educational institutions.

Examples: Academic records, grades, enrolment details, disciplinary actions.

Biometric Information

Data derived from unique physical characteristics of an individual, increasingly used for identification and security purposes.

Examples: Fingerprints, facial recognition data, retina scans, voice prints.

Expectation of Privacy

Privacy programs are based on a legal principle known as the *reasonable expectation of privacy*.



When you put content on social media, you generally have no reasonable expectation of privacy.

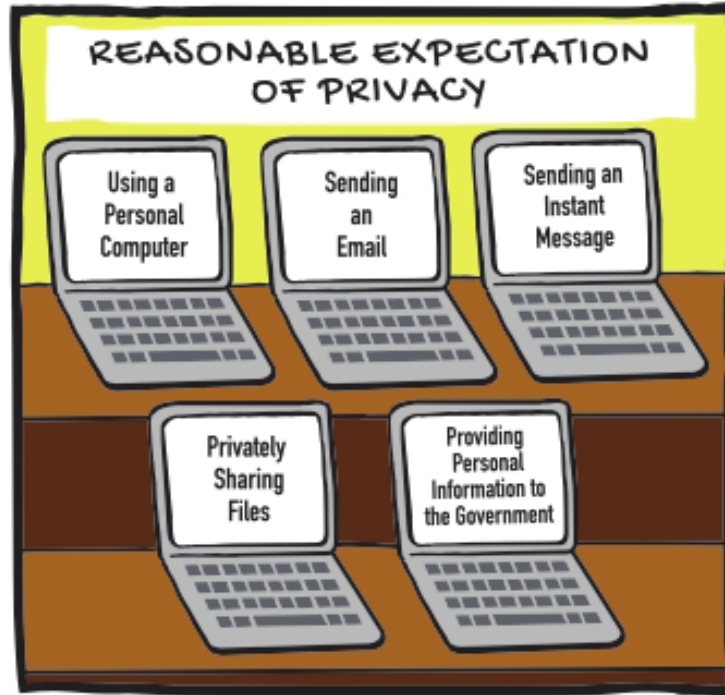


When you send a message to someone over email or instant messaging, you do have an expectation of privacy.

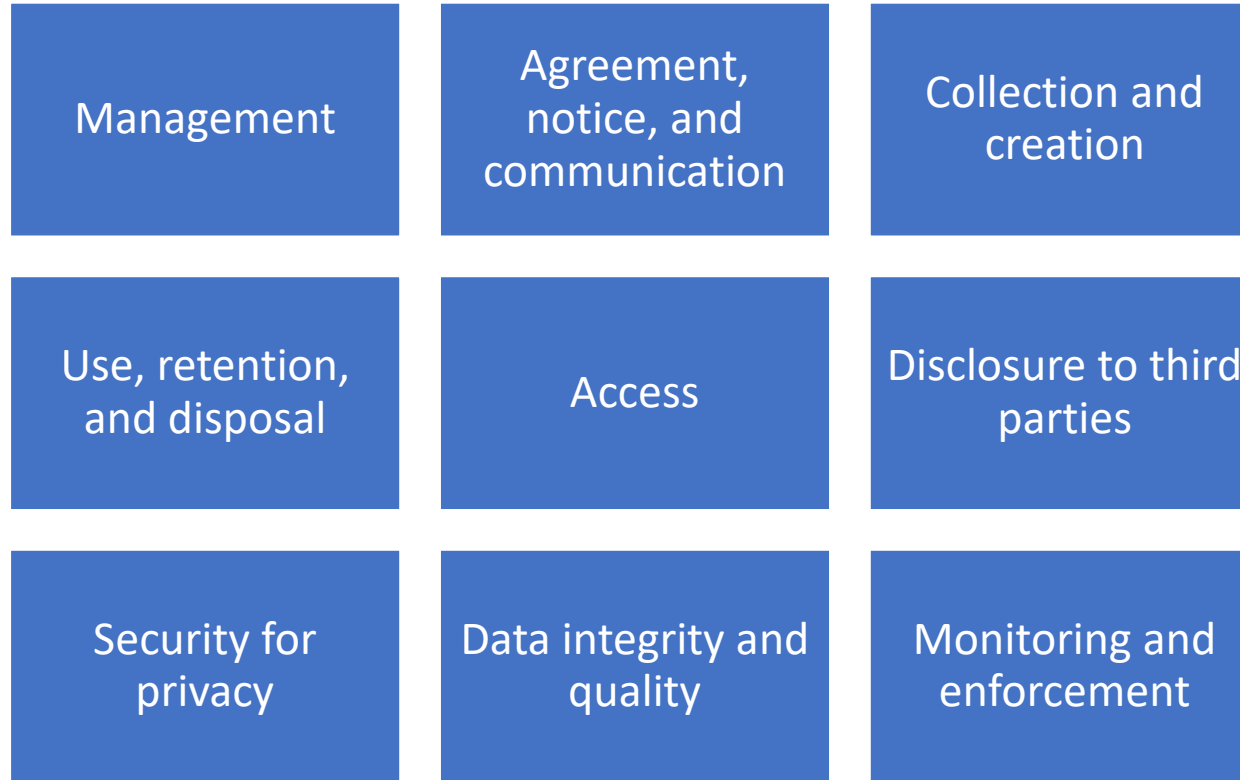


When you provide private information to a government agency through their website, you have a much greater expectation of privacy.

Do you have a reasonable expectation of privacy?



Privacy Management Framework (PMF)



1. Management



- Requires that organizations establish control over the management of their privacy program.
- The entity defines, formally documents, communicates, and assigns accountability for its PI (personal information) privacy policies and procedures.
- Example:
 - A company appoints a dedicated **Data Protection Officer (DPO)** and establishes a cross-functional privacy steering committee (including IT, Legal, and HR) to oversee data protection policies and ensure legal compliance across the organization.

2. Agreement, Notice, and Communication



- Requires that organizations **inform individuals** about their privacy practices and obtain agreement for information processing.
- The entity makes formal **agreements**, **notifies** and **communicates** with and offers choices when seeking data subject consents, including **reasons why** and purposes for which the entity seeks to obtain and use a data subject's PI.
- Example:
 - A mobile app displays a clear, easy-to-read **Privacy Notice** during the sign-up process and uses a pop-up banner to get explicit "opt-in" consent from users before tracking their location or sending marketing notifications.



3. Collection and Creation



- Governs the ways that organizations come into the possession of personal information.
- The entity collects and creates PI only for the **purposes identified** in its agreements with data subjects, and in ongoing communications with and notices provided to data subjects.
- Example:
 - Practicing **data minimization**, an e-commerce website only asks for a customer's name, shipping address, and email to process an order, purposefully avoiding unnecessary details like their date of birth or gender.

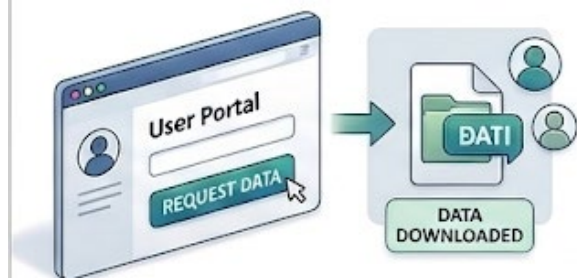


4. Use, Retention, and Disposal



- Organizations must maintain the privacy of personal information throughout its **life cycle**.
- The entity limits the **use** of PI to the purposes identified in the formal agreements/notices, and for which a data subject has provided explicit (or implicit) consent.
- The entity **retains** PI for the time necessary to fulfill the stated purposes identified in the formal agreements/notices or as required by laws or regulations.
- Once those purposes have been met, the entity securely **disposes** of the information.
- Example
 - A financial institution automatically runs a script that **permanently deletes** or **anonymizes** customer account data exactly seven years after the account is closed, adhering to regulatory timelines while ensuring old data isn't kept indefinitely.

5. Access



- Individuals should have the **right to access** information that an organization holds about them and, when necessary, to correct that information.
- The entity provides data subjects with access to their PI when requested or when asked to update and correct data errors or make changes.
- Example
 - A social media platform provides a **"Download Your Information"** button in the user settings, allowing individuals to request, view, and export a complete copy of all the personal data the platform has collected on them.



6. Disclosure to Third Parties



- Some challenging privacy issues arise when organizations maintain personal information about an individual and then **choose to share that information** with third parties in the course of doing business.
- The entity discloses PI to third parties only for the purposes identified in data subject privacy agreements and its privacy notice and with the **explicit consent** of the data subject.
- Example
 - Before a company shares its customer email list with an external email marketing vendor (like Mailchimp), they require the vendor to sign a strict **Data Processing Agreement (DPA)** that forbids them from using the emails for any other purpose.



7. Security for Privacy



- Protecting the security of personal information is deeply entwined with protecting the privacy of that information.
- The entity protects PI against unauthorized access, removal, alteration, destruction and disclosure (both physical and logical).
- Example
 - An organization protects its databases by enforcing **Advanced Encryption Standard (AES-256)** for data at rest, using HTTPS for data in transit, and requiring all employees to use Multi-Factor Authentication (MFA) to access personal data.



8. Data Integrity and Quality



- The entity maintains **accurate**, **complete** and **relevant** PI for the purposes identified in the notice and protects the representational integrity of the PI in its ongoing interactions with data subjects.
- Example
 - A healthcare portal prompts patients to review and confirm or update their mailing address, phone number, and emergency contacts every time they log in or check in for an annual appointment to ensure medical records stay accurate.

9. Monitoring and Enforcement



- The entity monitors **compliance** with its privacy policies and procedures and has procedures to address privacy-related **complaints** and **disputes**.
- Example
 - An internal audit team conducts **annual privacy compliance reviews** and uses automated logs to track who accesses sensitive data. If an employee accesses user files without a valid business reason, the company triggers formal disciplinary actions.





Privacy Preserving Browsing

- **Browser Protections**
- **Routing Protections**



جامعة الملك عبد الله
للعلوم والتقنية
King Abdullah University of
Science and Technology



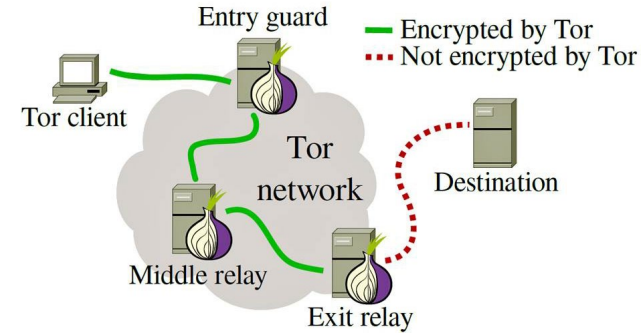
Privacy-Preserving Browsers

- **Brave** is built on **Chromium** (the same open-source foundation as Google Chrome), but it completely strips out Google's tracking code, background telemetry, and phone-home scripts.
- By default, it doesn't just block ads; it cuts off trackers at the network request level before they even load into your browser's memory.
 - **Aggressive Fingerprinting Protection:** It introduces random "noise" to your canvas and audio data, making your browser fingerprint change constantly so trackers can't build a static profile.
 - **Bounce Tracking Protection:** It detects when a link redirects you through an ad-tracker domain first and automatically bypasses the middleman.



The Onion Routing (TOR)

- Tor (The Onion Router) was created by the US Naval Research Laboratory to protect government communications.
- It is an open-source privacy protocol, not a "hacker playground."
- Working Principle uses 3 Relays:
 - **Guard Relay:** Knows who you are, but doesn't know what you are looking at.
 - **Middle Relay:** Knows nothing. It just passes encrypted data between the Guard and Exit.
 - **Exit Relay:** Knows what the website is, but has zero clue who sent the request.
- **Multi-Layered Encryption:** Your data is wrapped in three layers of encryption (like an onion). Each relay peels off exactly one layer to find out where to send it next.



TOR vs. Brave

Feature	Brave Browser	Tor Browser
Primary Goal	Speed, Ad-blocking, Anti-tracking	Total Anonymity, Anti-censorship
Network Path	Direct connection to the website	Multi-hop (Guard -> Middle -> Exit)
IP Address	Your actual IP is visible to the site	Hidden behind an Exit Node IP
Performance	Blazing fast (Faster than Chrome)	Slower due to multi-layered routing
Best Used For	Daily schoolwork, logging into personal accounts	Whistleblowing, circumventing censorship



جامعة الملك عبد الله
للعلوم والتقنية
King Abdullah University of
Science and Technology